

OLAY RAPORU

INC-2026-0824-01 – web01 Üzerinde SSH Brute Force ve Hesap Ele Geçirme

Sistem: web01 (Linux sunucu)

Tarih: 24 Ağustos

Veri kaynağı: Case1-auth.log(Splunk: index=main, sourcetype=linux_secure, source=Case1-auth.log)

Özet ve Kapsam

24 Ağustos günü, web01 sunucusunun izleme sistemi kısa bir zaman aralığında çok sayıda başarısız SSH giriş denemesi tespit etti. İnceleme, dış bir IP adresinin (203.0.113.66) 14:22-14:25 arasında sistemde var olan ve var olmayan kullanıcı adlarını sistematik olarak denediğini, 91 başarısız denemenin ardından “deploy” hesabı ile başarılı giriş sağladığını ve girişten saniyeler sonra /etc/shadow dosyasını okuyup yeni bir kullanıcı hesabı (svc-update) oluşturduğunu ortaya koydu.

İncelenen veri, web01’in Case1-auth.log kaydından alınan tek bir dosyadır; olay dış kaynaklı bir SSH brute force saldırısı ve bunu takip eden başarılı bir hesap ele geçirmedir.

Zaman Çizelgesi

Zaman	Kaynak	Olay	Varlık	Değerlendirme
08:03:11	auth.log	Başarılı SSH girişi	deploy@ 10.0.0.50 (iç ağ)	normal
08:14:52	auth.log	Başarılı SSH girişi	ayse @ 10.0.0.50 (iç ağ)	normal
08:21:07	auth.log	sudo apt update	ayse	normal
11:12:44	auth.log	Başarılı SSH girişi	deploy@ 10.0.0.50 (iç ağ)	normal
14:22:04	auth.log	Brute force başlangıcı	203.0.113.66	
14:22:04 –14:25:52	auth.log	91 başarısız SSH girişi (7 farklı kullanıcı adı)	203.0.113.66	
14:25:53	auth.log	Başarılı SSH girişi	deploy@ 203.0.113.66 (dış IP)	anormal
14:25:54	auth.log	sudo cat /etc/shadow	deploy	credential access
14:25:58	auth.log	sudo useradd svc-update	deploy	persistence girişimi
14:26:01	auth.log	svc-update (UID=1003) oluşturuldu	sistem	

Bulgular ve Kanıtlar

Bulgu 1 – Kaynak IP ve saldırı hacmi

SPL Sorgusu

```
index=main sourcetype=linux_secure source="Case1-auth.log" "Failed password"  
| rex field=_raw "from (?<src_ip>\d+\.\d+\.\d+\.\d+)"  
| stats count by src_ip
```

Çıktı

```
src_ip=203.0.113.66, count=91
```

Analiz:

Tüm başarısız SSH denemeleri tek bir dış IP'den geldi. 91 deneme yaklaşık 3 dakika 48 saniyeye yayıldı (14:22:04–14:25:52). Saniyede birden fazla deneme, otomatize bir araca işaret ediyor.

Bulgu 2 – Denenen kullanıcı adları

SPL Sorgusu:

```
index=main sourcetype=linux_secure source="Case1-auth.log" "Invalid user"  
| rex field=_raw "Invalid user (?<username>\w+)"  
| stats count by username
```

Çıktı:

```
admin (12), oracle (12), postgres (12), test (12) → sistemde tanımlı olmayan hesaplar
```

Ayrıca Accepted/Failed password satırlarından: deploy (18), root (15), ubuntu (10) denendi; bu üçü sistemde tanımlı gerçek hesaplar.

Analiz:

Saldırgan önce genel bir wordlist (admin, oracle, postgres, test) ile geziniyor, ardından sistemde gerçekten var olan hesaplara (root, ubuntu, deploy) yoğunlaşıyor.

Bulgu 3 — Başarılı giriş ve hesap ele geçirme

SPL Sorgusu:

```
index=main sourcetype=linux_secure source="Case1-auth.log" "Accepted password" "203.0.113.66"
```

Çıktı:

Aug 24 14:25:53 web01 sshd[3093]: Accepted password for deploy from 203.0.113.66 port 42580 ssh2

Analiz:

91. başarısız denemenin sadece 3 saniye sonrasında deploy hesabıyla başarılı giriş gerçekleşti.

Bulgu 4 — deploy hesabının normal davranışıyla karşılaştırma

SPL Sorgusu:

```
index=main sourcetype=linux_secure source="Case1-auth.log" "Accepted password" "deploy"  
| rex field=_raw "from (?<src_ip>\d+\.\d+\.\d+\.\d+)"  
| table _time src_ip
```

Çıktı:

08:03:11 — 10.0.0.50 (iç ağ)

11:12:44 — 10.0.0.50 (iç ağ)

14:25:53 — 203.0.113.66 (dış IP) ← anomali

Analiz:

deploy hesabı gün içinde iki kez normal şekilde iç ağdan giriş yapmış. Üçüncü giriş dış bir IP'den, hem de 91 başarısız denemenin hemen ardından geldi. Bu davranış kalıbı -kaynağın değişmesi + brute force sonrası ani başarı- hesabın brute force ile ele geçirildiğini güçlü şekilde destekliyor. Logda "bu gerçek deploy kullanıcısı değildi" diye doğrudan bir kanıt yok, ama bağlam bunu neredeyse tek makul açıklama haline getiriyor.

Ne doğrulardı: deploy hesabının meşru sahibiyle (varsa) teyit; kimlik sağlayıcı/VPN loglarında 203.0.113.66'nın tanınıp tanınmadığı.

Bulgu 5 — Girişten sonraki aktivite

SPL Sorgusu:

```
index=main sourcetype=linux_secure source="Case1-auth.log" "deploy" ("sudo" OR "useradd")  
| table _time _raw  
| sort _time
```

Çıktı:

14:25:54 — sudo: deploy : COMMAND=/usr/bin/cat /etc/shadow

14:25:58 — sudo: deploy : COMMAND=/usr/sbin/useradd -m -s /bin/bash svc-update

14:26:01 — useradd[3512]: new user: name=svc-update, UID=1003, GID=1003, home=/home/svc-update, shell=/bin/bash

Analiz:

Girişten 1 saniye sonra /etc/shadow (parola hash dosyası) okundu; 4 saniye sonra yeni bir kullanıcı (svc-update) oluşturuldu. Bu hız insan eliyle pratik olarak açıklanamaz, scriptli/otomatize post-exploitation davranışına işaret ediyor.

Etki

- Kimlik bilgisi ele geçirildi: deploy hesabının SSH parolası brute force ile kırıldı; sunucu üzerinde geniş yetkiye sahip olabilir.
- Parola hash'leri sızdırılmış olabilir: /etc/shadow okundu; bu dosya sistemdeki tüm yerel hesapların parola hash'lerini içerir. Saldırgan bu hash'leri sistem dışına çıkarabilirse, offline kırma yoluyla diğer hesapları da ele geçirebilir.
- Kalıcı erişim (persistence) kuruldu: svc-update adında yeni bir yerel hesap oluşturuldu. Bu hesabın parolası, SSH anahtarı erişimi veya sudo yetkisi bu log penceresinde görünmüyor ama varlığının kendisi, saldırganın deploy hesabı fark edilip kapatılsa bile sisteme geri dönebilecek ikinci bir kapı açtığı anlamına gelir.
- Bu bir iç uygulama sunucusu olduğu ve normalde yalnızca iç ağdan erişildiği belirtildiği için, dış IP'den SSH erişiminin mümkün olması başlı başına bir güvenlik açığı.

Öneriler

Öncelikli olarak deploy hesabının parolasının değiştirilmesi ve mevcut aktif oturumların sonlandırılması gerekmektedir. Bu hesabın brute force saldırısı sonucunda ele geçirildiğine dair kanıtlar yeterince güçlüdür. Aynı şekilde, saldırgan tarafından oluşturulan svc-update hesabının da hızlı bir şekilde kaldırılması gerekir.

Olayın asıl nedeni, SSH servisinin dış ağa (internete) açık olmasıdır. Söz konusu sunucunun normalde yalnızca iç ağdan erişilmesi gerektiği göz önüne alındığında, dış bir IP adresinin bağlantı kurabilmiş olması brute force saldırısını mümkün kılan temel etkindir. Bu nedenle SSH erişiminin yalnızca iç ağdan veya bir VPN/bastion sunucusu üzerinden yapılacak şekilde kısıtlanması önerilmektedir. Saldırıya kaynaklık eden IP adresinin (203.0.113.66) güvenlik duvarında engellenmesi de gerekmektedir; ancak bu tedbir tek başına yeterli değildir, aynı saldırı farklı bir IP adresinden tekrarlanabilir.

Parola tabanlı SSH kimlik doğrulamasının tamamen kaldırılıp SSH anahtarı (key) kullanımına geçilmesi en kalıcı çözüm olacaktır; çünkü brute force saldırısının başarılı olmasının temel nedeni parola ile giriş yapılabilmesi olmasıdır. Bunun yanı sıra, belirli sayıda başarısız giriş denemesinden sonra ilgili IP adresini otomatik olarak engelleyen bir mekanizma kurulmalıdır; bu olayda 91 denemeye kadar herhangi bir engellemenin devreye girmemiş olması önemli bir eksikliktir.

Ayrıca, /etc/shadow gibi kritik dosyalara erişim gerçekleştiğinde uyarı üretecek bir izleme mekanizmasının kurulması önerilmektedir; söz konusu erişimin gerçek zamanlı olarak fark edilebilmesi durumunda müdahale süreci çok daha hızlı işleyebilir. Son olarak, deploy hesabının erişim yetkisine sahip olduğu diğer sistemlerin belirlenerek, aynı kimlik bilgilerinin başka bir noktada kullanılıp kullanılmadığının kontrol edilmesi gerekmektedir.

Sonuç

Bu olay, dış kaynaklı bir SSH brute force saldırısının başarıya ulaştığı ve saldırganın erişimini kimlik bilgisi toplama (/etc/shadow okuma) ve kalıcılık (yeni hesap oluşturma) ile pekiştirdiği net bir vaka. Kanıt zinciri eksiksiz: kaynak IP, deneme sayısı, denenen kullanıcı adları, başarılı giriş anı, ele geçirilen hesabın normal davranışıyla karşılaştırılması ve girişten sonraki komutlar; hepsi tek bir log dosyasından, aynı Splunk sorgu setiyle doğrulandı. Öncelik, deploy hesabını ve svc-update hesabını derhal kapatmak, ardından SSH'in dışarıya neden açık kaldığını incelemek olmalı.